1. Опишите трехсторонний протокол распределения ключей между парами участников с использованием третьей стороны.

При описании протокола явно обозначьте роли всех трех сторон, назовите основные этапы (с указанием, кто, кому и что отправляет) и сформулируйте итоговый результат — какой ключ и между какими участниками устанавливается.

Ответ.

Классическим примером такого взаимодействия является симметричный протокол Нидхема-Шрёдера, (пример реализации – служба аутентификации Kerberos).

В общих чертах схема выглядит следующим образом. Есть три участника:

- A (Alice/Алиса) — сторона, инициирующая соединение.
- B (Bob/Боб) — целевая сторона соединения.
- S (Server/Сервер, обозначается как (Trent/Трент)) — доверенный центр распределения ключей (в Kerberos – Key distribution center (a.k.a KDC)).

Он заранее разделяет секретный симметричный ключ с каждым из участников: ключ (K_{AS}) известен только Alice и Server, а ключ (K_{BS}) — только Bob и Server.

Протокол состоит из трех этапов.

Этап 1: Запрос ключа.

Alice отправляет сообщение к Trent. В этом сообщении Алиса сообщает Server, что хочет связаться с Бобом. При этом передается:

- Идентификатор самой Алисы (A). Это несекретная информация, ее можно передать по открытому каналу (например, логин alice или IP-адрес). Server смотрит на этот идентификатор, чтобы понять, кто к нему обращается и каким секретным ключом (K_{AS}) нужно будет зашифровать ответ.
- Идентификатор Боба (B). Это несекретная информация, ее можно передать по открытому каналу (например, логин bob или IP-адрес). Server смотрит на него, чтобы понять, для кого Алиса запрашивает сессионный ключ и какой второй ключ (K_{BS}) использовать для создания «билета».
- Нонс (N_A) — случайное одноразовое число для защиты от повторных атак.

Для генерации nonce операционная система Алисы использует криптографически стойкий генератор псевдослучайных чисел (CSPRNG):

- В Linux - чтение из /dev/urandom или системный вызов getrandom().
- В Window - функции CryptoAPI (например, BCryptGenRandom).
- На аппаратном уровне - аппаратные генераторы случайных чисел (TRNG), которые встроены в современные процессоры (пример - команда RDRAND в Intel/AMD)

При этом:

- Число не должно повторяться (требование уникальности для защиты от replay attack).
- Число должно быть непредсказуемым. Злоумышленник, перехватив предыдущие nonce, не должен иметь возможности угадать, каким будет следующее.
- Число должно иметь достаточную длину. Обычно размер nonce составляет от 64 до 128 бит для устойчмвости от т.н. "Атаки дней рождений".

Этап 2: Генерация и распределение сессионного ключа Трентом и отправка его Алисе

Трент отправляет ответ Алисе. При этом трент генерирует новый случайный сессионный ключ ($K_{AB)}$. Этот сессионный ключ создается с помощью аппаратного или криптографически стойкого генератора случайных чисел. Он зашифровывает пакет ключом Алисы (K_{AS}). Внутри пакета находятся:

- Нонс Алисы (N_A) для проверки актуальности.
- Идентификатор Боба (B).
- Сам сессионный ключ (K_{AB}). Этот ключ будет использоваться исключительно для текущей сессии связи между Алисой и Бобом.
- «Билет» для Боба, зашифрованный ключом Боба (K_{BS}), содержащий тот же ключ (K_{AB}) и имя Алисы (A\). Выглядит это примерно так:

$$E_{K_{AS}}\left(N_A, B, K_{AB}, E_{K_{BS}}(K_{AB}, A)\right)$$

Что дает такая структура:

- Нонс (N_A) внутри шифра (K_{AS}) доказывает Алисе, что Трент создал этот ответ прямо сейчас (свежесть сообщения).
- Имя (B) внутри шифра (K_{AS}) защищает Алису от атаки подмены собеседника. Она точно знает, что Трент выпустил этот ключ именно для общения с Бобом, а не с кем-то другим.
- Вложенный «билет» $E_{K_{BS}}$ дает важное - Тренту не нужно самому связываться с Бобом. Он перекладывает эту задачу на Алису (как в МФЦ вам

выдают запечатанный конверт для передачи в другое ведомство). Алиса не может расшифровать или подделать этот кусок, так как не знает ключа (K_{BS}).

Этап 3: Передача «билета» от Алисы Бобу

Алиса расшифровывает сообщение от Трента, убеждается по нонсу (N_A), что это свежий ответ, забирает себе ключ (K_{AB}) и пересылает Бобу его зашифрованную часть («билет»).

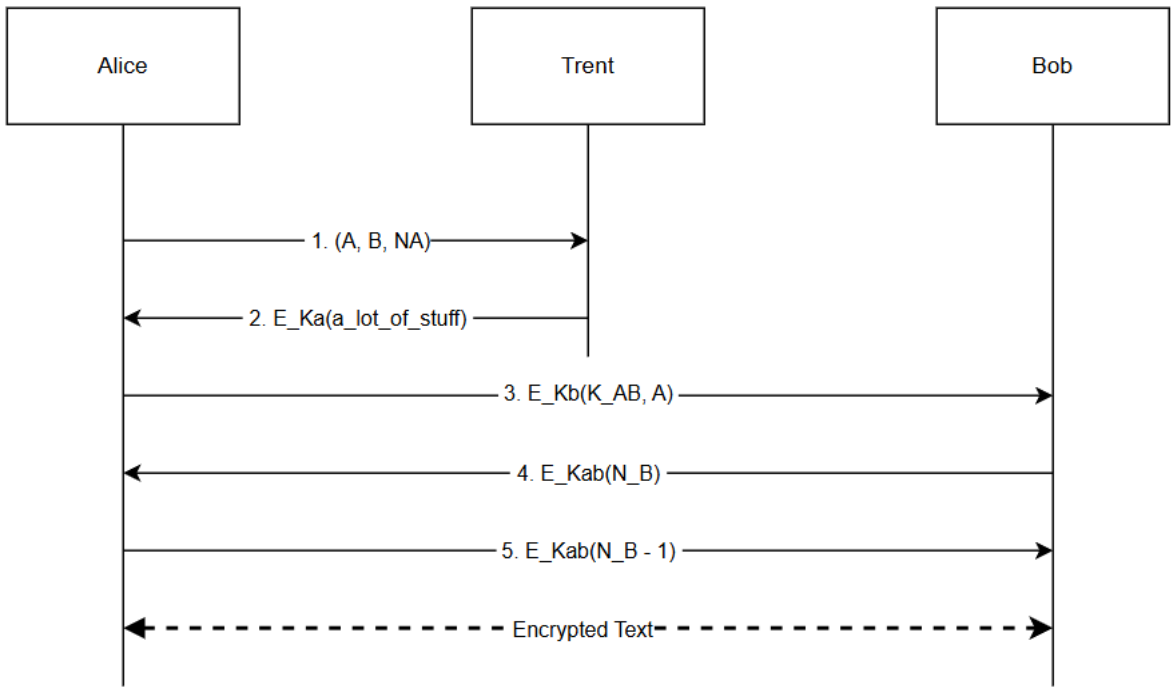
Этап 4: Подтверждение от Боба (Рукопожатие)

Боб расшифровывает билет своим ключом (K_{BS}), узнает сессионный ключ (K_{AB}) и имя Алисы. Чтобы доказать Алисе, что он владеет этим ключом, он генерирует свой нонс (N_B), зашифровывает его сессионным ключом и отправляет Алисе.

Этап 5: Финальное подтверждение от Алисы

Алиса расшифровывает нонс Боба, проводит над ним простое математическое действие (например, вычитает единицу), зашифровывает обратно ключом (K_{AB}) и отправляет Бобу. Это доказывает Бобу, что Алиса активна и тоже знает ключ.

Схематично все это будет выглядить так.



Таким образом, ~~сформировалось преступное сообщество, в простонародье «шайка»,~~ по результатам успешного выполнения протокола между Алисой и Бобом устанавливается общий симметричный сессионный ключ (K_{AB}). Этот ключ является временным, известен только Алисе и Бобу (изначально сгенерирован доверенным Трентом) и используется для последующего шифрования и контроля целостности всех передаваемых между ними данных в рамках текущей сессии.